

Security & Privacy Review Pack

ใช้เอกสารนี้ตรวจสอบความพร้อมด้าน security/privacy ก่อน pilot

ขอบเขตข้อมูลที่ถูกถือว่า sensitive

- ข้อมูลระบุตัวผู้ป่วย: HN, ชื่อ, วันเกิด, เพศ, เบอร์ติดต่อ
- ข้อมูลเวชระเบียน: encounter, SOAP, diagnosis, vital sign, prescription
- ข้อมูลยาและแพทย์
- controlled substance events และ witness/re-auth metadata
- invoice/payment/refund/insurance claim
- file attachments และ clinic logo/file assets
- audit logs และ auth/session events

Access Control Review

Area	Check	Result	Note
Role matrix	docs/role-permission-matrix.md reviewed		
Admin overrides	clinic-level grant/deny reviewed		
Doctor access	patient/clinical read/write appropriate		
Nurse/front desk access	queue/visit workflow appropriate		
Pharmacy access	stock/dispense/override permissions appropriate		
Billing access	invoice/payment/refund permissions appropriate		
Audit access	limited to admin/owner/IT as agreed		

Authentication Review

Check	Result	Note
API_TOKEN set for non-local environment		
AUTH_SESSION_SECRET set and private		
login code policy agreed		
OIDC/JWKS plan reviewed if provider is used		
MFA claim requirement decided		
inactive users cannot authenticate		
user deactivation process documented		

Privacy/PDPA-Oriented Checks

Check	Result	Note
Only necessary patient data collected		

Check	Result	Note
Consent records workflow reviewed		
File upload allowed MIME types reviewed		
File storage private path configured		
Audit logs available for sensitive actions		
Data export/report access restricted		
Incident contact and escalation path assigned		

Operational Security

Check	Result	Note
Production readiness strict check passed		
Backup encryption/storage location reviewed		
Restore drill completed		
Rollback drill completed		
Security incident tabletop completed		
Monitoring owner assigned		
Backup owner assigned		
Incident owner assigned		

Open Security Decisions

Decision	Owner	Due date	Status
External identity provider or local pilot auth			
MFA required for pilot			
Report export access policy			
File retention policy			
Backup retention policy			

Minimum Pilot Gate

- No shared admin account
- No default/weak token in pilot
- Persistent private file storage configured
- Backup/restore evidence completed
- Audit access limited and reviewed
- Incident owner and contact path assigned